Response to Reviewers

Manuscript: TOMWare.M: Selective Pintool-Based Countermeasures against Anti-Instrumentation Techniques in Windows Executables

Journal of Computer Virology and Hacking Techniques | Submission `c05a1271-d18d-468d-8c50-9dc8b6c10952`

Decision: major revision. Date of this letter: 26 October 2026.

Each item: (a) concern, (b) evidence we have, (c) where the revised manuscript applies it.

We thank the Editor and the Reviewer. This letter answers every comment with measurements from the isolated guest (snapshot `tomware_go`, Pin 3.28.98749, campaign DLL SHA-256 starting `4BBC6270`). The revised manuscript applies the changes listed in (c) at the stated locations. TMW0 means Pin with TOMWare loaded and all five knobs off (`-q`); it is not bare Pin. EMPTY is Pin with an empty pintool. We do not mix the submitted 10 s / 31-PE tables with a later 60 s / 50+50 campaign unless the window is named. Practical recovery of suppressed malware behaviour is not demonstrated.

Software and artefacts

Guest login laboratory VM; one Pin at a time; host-only network. Timing raw file: `experiment/jcvht_revision/results/matched_timing_n30.csv` (SHA-256 prefix `76208218`; N=30, no attempt discarded). Use the conventional median (mean of the two central values when n is even) in `matched_timing_summary_conventional.csv`. Do not use `matched_timing_summary.csv` (it still stores the lower element of the central pair).

Editor (Eric Filiol)

E.1 -- Accurate results, no overstatement, limitations stated

(a) Reviewer concern. Ensure results are accurately reported, overstated conclusions rewritten, and limitations fully explained; submit a point-by-point response.

(b) Response. This letter is that response. We no longer attribute the old Table 6 reduction (4080 to 2081) solely to SkewMask. Remaining alive under Pin is not preserved malware behaviour. The 14-sample x 5-knob PASS table is an oracle result, not proof that those binaries exercised the five checks. Four candidate malware/benign case studies (23 Oct 2026) produced no extra file, stdout, or identified child tree -- so we do not claim practical recovery of hidden behaviour.

(c) Manuscript change (location). Applied in the Abstract and the single Limitations subsection. The 14-sample table remains an oracle/compatibility result (caption note). The four unsuccessful case attempts are Table (case-study attempt) in the Discussion.

Reviewer -- Major 1 (timing experiment)

M1.1 -- Matched workload, all attempts, Pin without -go

(a) Reviewer concern. Table 6 compared -go against -do, confounding artificial overhead with the countermeasure. Compare -go vs -go -do at fixed workload; also show ordinary Pin without -go. Report all attempts.

(b) Response. Done on TestOverhead.exe, pre-fixed N=30, every attempt kept. Arms: TMW0 (Pin + TOMWare, knobs off, -q), GO (-go -q), GO_DO (-go -do -q). TMW0 is not ordinary / bare Pin. Conventional medians (ticks): TMW0 2,433.285 (30/30 below 3,000); GO 3,083.210 (11/30 = 36.7%, Wilson 95% [21.9%, 54.5%]); GO_DO 2,104.770 (30/30, Wilson [88.6%, 100%]). GO min-max 2,722-3,845; GO_DO 2,073-2,146; TMW0 2,168-2,750. The old 9/31 re-execution cell is not used. The submitted -go vs -do pair (including any 49% reading of 4080 vs 2081) is confounded.

(c) Manuscript change (location). The matched N=30 table is now the main timing result in the Evaluation (Table 1 below). The originally submitted -go versus -do table is moved to an appendix and labelled as confounded; its numbers are kept. Abstract: compensation rate 11/30 vs 30/30, not a binary 'effective'. Body sentences that treated the old cell as a SkewMask gain are replaced.

Table 1. Timing oracle, TestOverhead.exe, fixed N=30, all attempts retained.

Arm	Knobs	N	Median ticks	Min-max	Below 3,000
TMW0	-q	30	2,433.285	2,168-2,750	30/30 (100%)
GO (baseline)	-go -q	30	3,083.210	2,722-3,845	11/30 (36.7%)
GO_DO (treatment)	-go -do -q	30	2,104.770	2,073-2,146	30/30 (100%)

M1.2 -- Sequential / concurrent / clock / early wait

(a) Reviewer concern. Test sequential and concurrent waits, repeated clock reads, and an early-returning wait. If a coherent timeline cannot be guaranteed, state a limitation.

(b) Response. Oracle TestConcurrentWaitsLogged (seq Sleep, two overlapping Sleeps, TickCount, alertable WaitOne) with per-event QPC and PID in `events.jsonl`. Without -go, N=5, 24 Oct 2026 (`waits_logged.csv`): 20/20 exit 0, no 90 s timeout. Native 5/5: Join-wall median 213.678 ms < seq 406.218 ms, alertable ~46 ms. EMPTY / TMW0 / -do: Join-wall medians 571.867 / 553.862 / 517.802 ms (longer than seq). That is not serialization: the two Sleep QPC intervals still intersect under Pin (median intersection ~207 / 212 / 196 ms; overlap fraction 0.70-0.99). The failed model is Join-wall < seq, from thread-create/Join/JIT cost, not lost Sleep overlap. TickCount never ran backwards on the single pair (20/20); that does not prove general monotonicity. The native ~46 ms early WaitOne is lost under Pin (291-636 ms). WaitOne is not SleepEx. -do does not restore Join-wall < seq. EMPTY is Pin + EmptyPinTool.dll, not Pin without a tool. SkewMask accumulates a process-wide offset (AccumulateSkewTicks). We do not claim a globally coherent clock under Pin.

(c) Manuscript change (location). Applied in Section 5.5 and Table 1b below. We do not write that Pin serializes concurrent Sleeps or that SkewMask restores overlap geometry.

Table 1b. Wait model, TestConcurrentWaitsLogged, N=5, no -go, 24 Oct 2026. Conventional medians (ms).

Arm	seq 2x200	par wall	TickCount+50	WaitOne(500)
NAT	406.218	213.678	62	45.867
EMPTY (Pin+empty tool)	433.421	571.867	62	445.610
TMW0 (-q)	441.209	553.862	78	441.411
DO (-do -q)	414.809	517.802	56	383.428

M1.3 -- Instrumented runs that timed out with empty stdout

(a) Reviewer concern. Diagnose instrumented cases that ended with no output.

(b) Response. Under -go / -go -do the same wait oracle hits collector timeout -2 in 90 s with empty stdout (`module32_waits.csv`). Cause: SimulateOverhead inserts 10,000 __nop before every instruction. That is the artificial-load generator used by TestOverhead, not a SkewMask crash and not a backward clock. TestOverhead itself completes under -go and -go -do (Table 1). The wait oracle is therefore reported without -go.

(c) Manuscript change (location). One sentence in Section 5.5: -2 on TestConcurrentWaits + -go is SimulateOverhead timeout, not a SkewMask crash.

Reviewer -- Major 2 (resource changes)

M2 -- Explain CPU/WS, milestones, window, process tree

(a) Reviewer concern. Table 9 reports very large WS/CPU reductions under SkewMask. Explain program behaviour, milestones, observation window, and process tree (parent vs child).

(b) Response. Agreed that 'still running' is not 'the same work'. Two windows must stay labelled:

(1) This manuscript, Table 9: 10 s, 31 PE. The published working-set reductions (about 87% / 74%) and CPU reductions (about 38% / 29%) belong only to that protocol; they are two different quantities, not two WS figures.

(2) Later 50+50 campaign (same Pin 3.28.98749, DLL 4BBC6270, seed 705851366; persistent window 60 s): SkewMask lengthens wall-clock. Benign persistent TMW_DO minus TMW0: +55,452 ms [30,685, 57,031]. Malicious persistent: +37,387 ms [26,146, 42,770] (n_pairs=23, not 25). WS TMW_DO-TMW0 benign P -3.2 MB [-58.3, +0.4] (CI includes 0); malicious P -22.7 MB [-94.9, -10.7]. CPU rises because the process stays scheduled. This is not a performance gain and does not replace Table 9.

Four targeted runs (MAL_03, MAL_07, MAL_10, BEN_06) recorded new_files=0 and empty stdout. child_count under Pin is not a process tree (pin.exe leftovers). We therefore cannot attach named milestones or a parent/child tree to Table 9.

(c) Manuscript change (location). Applied in the Table 9 caption (window named 10 s / 31 PE; percentages are not a gain) and in a new 60 s addendum table. No named milestone or per-PID tree was added; that gap remains.

Reviewer -- Major 3 (practical benefit)

M3 -- Check + branch + extra behaviour

(a) Reviewer concern. Controlled detectors and corpus executions do not show that the 14 malware samples attempted the supported checks, nor that TOMWare recovered hidden behaviour. Provide a few case studies: identify the check, compare Pin-only vs countermeasure, show extra behaviour (unpack, config, file, registry, network).

(b) Response. We agree. The oracle PASS table is not evidence that each malware sample implemented that check. A later module-counter dump (30 PE, different live-dump DLL) is only a trace: ProcessEnum 0/269, memcmp 0 PIN_ matches; SkewMask fired on BEN_06, MAL_03, MAL_07, MAL_10. That does not identify a check in the PE.

On 23 Oct 2026 we ran those four binaries NAT / TMW0 / -do (60 s). Results (`case_studies_by_run.csv`):

(c) Manuscript change (location). Applied in the Discussion and in Table 2 below. The manuscript states that practical recovery of suppressed malware behaviour is not demonstrated. The 14-sample table remains oracle/compatibility only.

Table 2. Case-study attempt, 23 Oct 2026. Knob = -do. Timeout 60 s. new_files=0 and empty stdout on every row.

Sample	NAT	TMW0 (-q)	-do -q
MAL_03	timeout 60 s	ACCESS_VIOLATION 0xC0000005 (35 s)	timeout 64 s
MAL_07	exit 0 in 1.4 s	ACCESS_VIOLATION 0xC0000005 (4 s)	timeout 62 s
MAL_10	timeout 60 s	timeout 64 s	timeout 64 s
BEN_06	exit 3 in 1.0 s	exit 3 in 3.8 s	timeout 62 s

MAL_03 and MAL_10 already last the full window natively, so -do adds no extra artefact. MAL_07 / BEN_06 lasting longer under -do is the same wall-clock stretch already measured on the 60 s campaign; it is not unpack, a drop, a registry key, or a C2 attempt (network stays host-only). We do not treat 'still alive at 60 s' as a case study. Crashes are retained (0xC0000005), not discarded.

Reviewer -- Major 4 (functional tests)

M4.1 -- Module32 positive control

(a) Reviewer concern. Module32 replacements lacked a positive control. Cover pass-through vs masked calls, correct enumeration termination, unrelated entries preserved.

(b) Response. TestProcessEnum covers Process32* / GetModuleHandle*, not Module32. TestModule32.exe (Etapa 4) already showed termination + kernel32 (module_count=29, pinish=0 even without -dp). That did not prove a pinvm filter. On 24 Oct we added TestModule32Fixture: a copy of `version.dll` loaded as `%TEMP%\pinvm.dll` (dummy name, not real Pin). `module32_fixture.csv`: NAT fixture_pinvm=1 pinish=1 count=32; TMW0 fixture_pinvm=1 pinish=1 count=31; -dp and -da fixture_pinvm=0 pinish=0 count=30; kernel32=1 and terminated=True on all four. Dedicated ProcessEnum file `processenum_base.csv`: NAT pin.exe=0 (no Pin); TMW0 pin.exe=3; -dp=0; -da=0.

(c) Manuscript change (location). Applied as two addendum tables after the original TestProcessEnum table (Module32 fixture; dedicated pin.exe counts). The fixture is not a real Pin module.

M4.2 -- memcmp family beyond memcmp

(a) Reviewer concern. Cover pass-through versus masked calls on the supported memory-compare interfaces.

(b) Response. InstMemcmpMask hooks 12 routines (memcmp, _memcmp, __acrt_memcmp, bcmp, memicmp, _memicmp, _memicmp_l, memcmp_s, wmemcmp, wmemcmp_s, RtlCompareMemory, RtlEqualMemory). TestMemoryScan calls memcmp only; base -q finds PIN_ strings, -dm reports PIN_=0. Session 1 (23 Oct, `memcmp_variants.csv`) reached memcmp and _memicmp then aborted with CLR 0xE0434352. Session 2 (24 Oct, try/catch, `memcmp_variants_v2.csv`) exercised three exports with no abort: memcmp, _memicmp, RtlCompareMemory -- native/TMW0 = PASS; -dm/-da = MASKED. RtlEqualMemory and wmemcmp = NOT_EXERCISED (EntryPointNotFoundException on ntdll / ucrt / msvcrt). The line memcmp_passthrough=SAME_BAD ret=0 compares 7 bytes of AAAAAAAA vs AAAAAAAB, which are equal by construction; it is not a failing pass-through and not a tool defect. We claim three APIs, not five.

(c) Manuscript change (location). Applied as an addendum table after the original TestMemoryScan table. Three C# APIs are cited; wmemcmp and RtlEqualMemory remain NOT_EXERCISED. SAME_BAD is not cited as a defect.

M4.3 -- Combined -da smoke test

(a) Reviewer concern. Add a small -da test on the supported oracles.

(b) Response. Done, exit 0 on all five (`04_oracles/from_vm/da_oracles.csv`): TestAntiDebug -gdb -da -q all zeros; TestProcessEnum pin.exe=0; TestGetEnvironments PIN_* =0; TestMemoryScan PIN_/pin.exe/pinvm/pinipc =0; TestOverhead 2,040.7 < 3,000.

(c) Manuscript change (location). The sentence that -da was not evaluated is replaced. A five-detector smoke-test table is added. -da does not enable -go and is not a 3,100-run campaign.

Reviewer -- Minor comments

m1 -- Reproducibility

(a) Reviewer concern. Pin the repository to a release or commit; state the observation interval and corpus selection.

(b) Response. Evaluated software: Pin 3.28.98749; TOMWare.dll SHA-256 prefix 4BBC6270; snapshot tomware_go; timing seed/file as above. A previously cited git short hash 3040df7 is stale relative to this letter; identify the build by the DLL hash, not that commit. Windows: this paper's complementary tables = 10 s persistent / natural completion for short-lived. The 50+50 campaign = 60 s / 120 s -- label which table uses which. Corpus of the submitted paper: 17 benign + 14 malicious Windows PE in docs/avaliacao/ and experiment/corpus/; exclusions in exclusions.csv. We do not invent VirusTotal family names.

(c) Manuscript change (location). Applied in Methods: Pin 3.28.98749, DLL prefix 4BBC6270, snapshot tomware_go, 10 s window for this paper. The stale hash 3040df7 is removed.

m2 -- Repeated limitations; Table 8 spacing

(a) Reviewer concern. Shorten repeated limitations; fix Table 8 spacing (TestProcessEnum overflowing).

(b) Response. Editorial. Collapse duplicate limitation paragraphs into one subsection. Wrap the TestProcessEnum column.

(c) Manuscript change (location). Applied as one Limitations subsection and a wrap of the Table 8 TestProcessEnum column. No new experiment.

m3 -- Abstract

(a) Reviewer concern. Revise the 'all five countermeasures' sentence after the corrected timing evidence.

(b) Response. The five modules are selectively enabled and independently oracled. SkewMask's quantitative claim is the matched 11/30 vs 30/30 rate (Table 1), not the old -go vs -do cell and not the 10 s WS percentages.

(c) Manuscript change (location). Applied in the Abstract: five selectively enabled, independently oracled modules; SkewMask claim is 11/30 vs 30/30; TMW0 is named as Pin + TOMWare with knobs off, not ordinary Pin.

Sentences this revision must not contain

155/155. 9/31 as a success rate. -87% or -38% as a gain. 'SkewMask always hides Pin.' 'The malware used the five checks.' Superiority over Arancino (no bake-off; public Arancino is Pin 2.14 + 32-bit). Crash-exit for collector label 6,517 (that figure is an IEEE Access campaign label = exit unknown, not a JCVHT result). Mixing 10 s / 31 PE with 60 s / 50+50 as one protocol. A case-study claim for MAL_03 / MAL_07 / MAL_10 / BEN_06. TMW0 called 'ordinary Pin'. The old 49% / 4080-vs-2081 cell as this revision's result. '-da was not evaluated' left in the body.